Care Access Navigator

RBAC Model: Role-Based Access Control Design

IAM + GRC Healthcare Cybersecurity Capstone | Synthetic data only | Derived from Project Design Documentation v1.1

1. Purpose and Scope

This document defines the role-based access control (RBAC) model for the simulated Care Access Navigator healthcare environment. It covers seven roles (Clinician, Nurse, Billing, HR, IT Support, Security Analyst, Vendor) and six systems (EHR Simulator, Billing App, HR App, Patient Portal, Keycloak, SIEM). All identities and data are synthetic.

Note: the project design document defines the roles and applications but not the detailed permissions. The permissions below are design decisions based on job responsibilities and least privilege, and can be edited as the project evolves.

2. Design Principles

- Least privilege and minimum-necessary access to ePHI.
- Access is requested with a business justification, approved by a manager, validated by IAM/Security, provisioned, then verified.
- Access changes with the joiner-mover-leaver (JML) lifecycle and is checked in periodic access reviews.
- Privileged and vendor access is time-bound and requires MFA. Break-glass access is exceptional and governed.
- Access is granted to roles (Keycloak groups), never directly to individuals.

3. Role-to-Permission Matrix

Codes: R = read, W = write, RW = read/write, A = administer, RL = read (limited / minimum necessary), RWL = read/write (limited scope), SS = self-service only, - = no access.

Role	EHR Simulator	Billing App	HR App	Patient Portal	Keycloak (IAM)	SIEM / Logs
Clinician	RW	-	SS	RW	-	-
Nurse	RWL	-	SS	RW	-	-
Billing	RL	RW	SS	-	-	-
HR	-	-	RW	-	-	-
IT Support	-	-	-	A	RW	-
Security Analyst	R	-	-	-	R	R
Vendor	RWL	-	-	-	-	-

Permission notes

- Clinician / EHR: full chart, orders, prescribing.
- Nurse / EHR: vitals, care notes, medication administration; no prescribing; scoped to assigned unit.
- Billing / EHR: demographics, insurance, encounter codes only; no clinical notes.
- IT Support: Patient Portal configuration and availability only, no patient data content. Keycloak: password reset, unlock, group assignment via approved ticket.
- Security Analyst: EHR audit logs only; Keycloak audit read plus account containment during incidents.
- Vendor: test/simulated environment only; time-bound; sponsor required; no production ePHI.
- HR triggers JML events through HR record changes but has no rights in Keycloak.

4. Role Attributes and Controls

Role	Approver	MFA	Privilege	Review	Special Conditions
Clinician	Department manager	Yes	Standard (high ePHI)	Quarterly	Watch for excessive ePHI access (VIP or unrelated patients)
Nurse	Nurse manager	Yes	Standard (ePHI)	Quarterly	Access scoped to assigned unit
Billing	Billing manager	Yes	Standard (limited ePHI)	Quarterly	No clinical notes
HR	HR director	Yes	Standard (PII)	Semi-annual	Authoritative source for JML
IT Support	IT manager + Security	Yes (strong)	Privileged	Monthly	Separate admin account; no self-approval; break-glass eligible
Security Analyst	Security lead	Yes (strong)	Privileged	Monthly	Cannot approve own access; actions logged
Vendor	Business sponsor + Security	Yes	Restricted, expiring	At expiry (e.g. 90 days)	Sponsor required; auto-disable on end date; no production ePHI

5. Illustrative Synthetic Users

User ID	Name (synthetic)	Role	Scenario Supported
u.clin01	Dr. Alice Morgan	Clinician	Baseline access
u.nurse01	Ben Carter	Nurse	Mover: Nurse to Billing (remove clinical EHR access, add Billing)
u.nurse02	Dana Lee	Nurse	Excessive ePHI access detection
u.bill01	Carla Ruiz	Billing	Access review: mismatched access found
u.hr01	Evan Patel	HR	Joiner/leaver initiator
u.it01	Frank Osei	IT Support	Privilege escalation detection
u.sec01	Grace Kim	Security Analyst	Incident investigation and containment
u.vend01	Hank Vega	Vendor	Expired vendor access detection
u.term01	Ivy Chen	Nurse (disabled)	Disabled-user activity detection (former nurse)

6. Separation of Duties

- The requester cannot approve their own access. IT Support and Security Analysts cannot approve or provision their own privileged access.
- Billing plus Clinician access in one account is a conflict and is flagged in access reviews.
- HR can trigger lifecycle events but cannot grant application roles.
- Security Analysts can contain accounts but cannot modify logs or ePHI.
- IT Support has no ePHI content access.

7. Keycloak Implementation Mapping

- Groups: grp-clinician, grp-nurse, grp-billing, grp-hr, grp-itsupport, grp-secanalyst, grp-vendor
- Client roles per app: ehr-read, ehr-write, ehr-audit-read, billing-rw, hr-rw, portal-admin, siem-analyst
- Group-to-role mapping: each group receives only the client roles shown in the matrix; the full mapping is in the Keycloak_Mapping sheet of the Excel workbook.
- Attributes: sponsor and expiry_date (vendors), department.
- Policy: MFA required for all roles, with stronger authentication for privileged groups.

8. Break-Glass (Emergency Access)

- Eligible: Clinician and Nurse for emergency EHR access outside normal scope; IT Support for emergency admin access.
- Requires a documented reason and is time-limited (e.g. 4 hours), then auto-revoked.
- Every use generates an automatic SIEM alert.
- Every use receives a post-event review by the Security Analyst and Manager, logged as evidence.

9. Related Deliverable

The editable companion workbook, Care_Access_Navigator_RBAC_Matrix.xlsx, contains the roles, applications, RBAC matrix (with dropdowns), role attributes, users, SoD rules, Keycloak mapping, and break-glass sheets. Add new roles or applications there first, then update this document.